Reliability work, scoped delivery

New signup replay and protected Inventory history; accepted audit policy and source-aligned project documentation.

516
tests / subtests pass

30
runtime checks pass

22
validation gates pass

WHAT CHANGED

Owned area	Behavior now available
Auth signup NFR-11	An optional UUID key atomically saves one user, one outbox event and the original 201 response. Equal retries replay; changed valid input returns 409. Receipt retention: 24 hours.
Inventory history NFR-08	Migration 006 rejects UPDATE, DELETE and TRUNCATE of movements and waste. Inserts continue. Startup/readiness checks actual ALWAYS trigger bindings.
Auth audit NFR-08	Best effort is accepted for this iteration. Bounded retry and failure diagnostics remain; a persistent audit-write failure can still lose the record.
Proposal / ADRs	Owned facts and protocol/data paths are updated. ADR-006 matches Accepted in the supplied proposal; ADR-007 remains Proposed.

COMPATIBILITY AND SCOPE

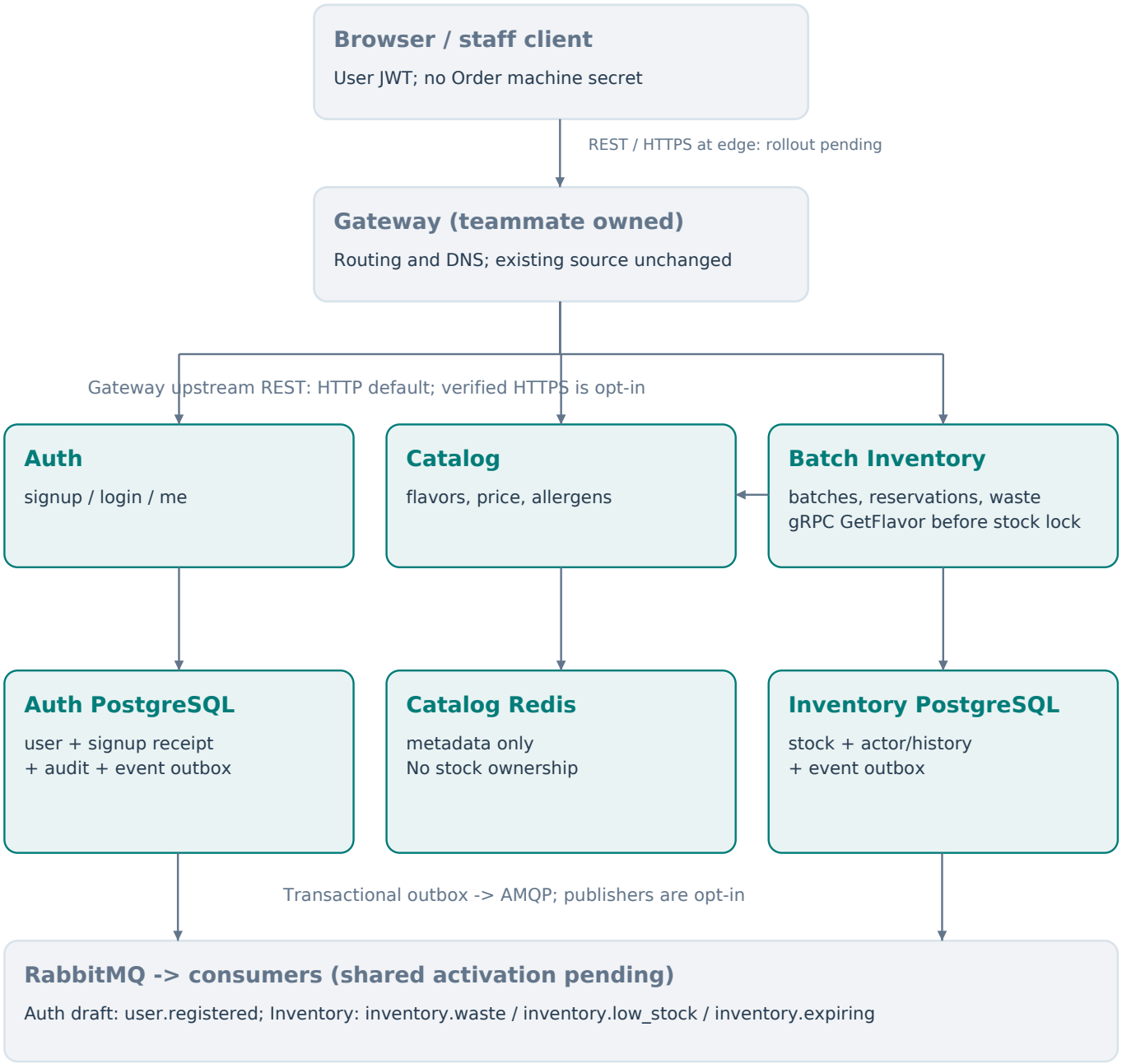
Existing no-header signup callers keep their behavior. Login validates current credentials and account status on every call and issues tokens afresh; no token-response cache is added. Catalog runtime is unchanged and passes the regression suite.

Changes are limited to owned services, their tooling and documentation. Gateway/Order source, shared contracts, shared Compose and shared broker topology are unchanged. No team database migration or deployment was performed.

Branch: catalog-nfr-privacy-audit
Delivery: focused commits and branch push; no new pull request.

Request paths and private data

Service discovery uses Docker DNS. Protocols and owned persistence are explicit; shared activation remains coordinated.



Internal callers: Order reads Catalog via versioned gRPC; Inventory RPCs require its separate machine credential. Inventory reads Catalog before its own stock transaction. Neither reads the other service's private database.

Discovery: shared names auth-service / catalog-service / batch-inventory-service; isolated checks use auth / catalog / inventory aliases. Owned TLS requires CA and hostname verification (TLS 1.2+). Current Order clients need owner TLS support before shared gRPC activation.

Decisions and rollout order

Additive migrations stay in owned stores. Compatibility tests are local evidence, not a shared deployment receipt.

AUTH: ORIGINAL SIGNUP RECEIPT, CURRENT LOGIN CHECK

Migration 004 adds a private receipt table and expiry index. A unique UUID claim, user creation, user.registered outbox row and original response share one transaction. Concurrent equal requests return the same user; a changed valid request conflicts. A failed response write rolls back all facts; a lost commit acknowledgement is recovered by retry.

Only normalized non-secret fields use SHA-256. Password equality uses the original salted bcrypt hash; plaintext and fast password digests are never stored. The private proof expires after 24 hours. Cleanup removes at most 1,000 expired receipts per batch, normally each minute; a database outage can delay physical deletion. Admission limits still apply.

Replay emits no second registration audit and does not reset lockout. It returns an original signup snapshot, not current account authority or a token. Login always checks current credentials/status. The shared all-mutations NFR wording still needs an explicit credential-endpoint clarification.

INVENTORY: APPEND EVIDENCE, PRESERVE THE PAST

Migration 006 adds UPDATE/DELETE row guards and TRUNCATE statement guards on inventory_movements and waste_records, enabled ALWAYS (including replica mode). Rejected DML returns SQLSTATE 23514. New production, reservation and waste evidence still inserts in the stock transaction. Old IDs, balances, timestamps and unknown actor NULLs remain intact.

Readiness checks actual trigger/function/event bindings as well as every migration marker. A missing, disabled or replica-only guard fails readiness. Administrators retain DDL authority; these guards are not an external tamper-proof audit store.

DEPLOYMENT SEQUENCE FOR OWNERS

- Coordinate the Inventory writer/DDL window. Run Auth migration 004 (or its existing startup migrator) and Inventory migrations through 006 before the new Inventory binary.
- Start with existing transport defaults. Verify health/readiness and a synthetic authorized mutation. No shared environment has been migrated in this delivery.
- Agree Auth event draft, routing and receiving topology before enabling its publisher. Consumers own stable-ID deduplication and DLQ.
- Provision service certificates and caller CA trust. Order/Gateway owners adopt the corresponding TLS settings before shared activation.

Evidence and document corrections

Verified against the current branch in isolated PostgreSQL, Redis, RabbitMQ and real executable/container paths.

Verification	Observed result
Race-enabled suites	Auth 241 + Catalog 180 + Inventory 94 = 515 passing tests/subtests. The macOS multi-peer skip passes separately on Linux: total 516.
30 runtime checks	Gateway 12; Auth broker/process 8; Inventory recovery/event routes 5; new signup executable restart/cleanup 5. Four service images built; Gateway/Order source unchanged.
22 validation gates	Format, vet, module integrity; OpenAPI, protobuf lint/build, event examples/privacy, Compose, generated-code consistency and whitespace.

CORRECTIONS TO CARRY INTO THE PROPOSAL

- Audit User-Agent: 512 Unicode characters. Events: LOGIN_SUCCESS, LOGIN_FAILED, LOGIN_ERROR, USER_REGISTERED.
- Defaults: bcrypt cost 12 (allowed 10-14); JWT lifetime 15 minutes (allowed 1 second-1 hour). Inventory advisory keys use the first 64 bits of SHA-256, not hashtext.
- Inventory routing keys are inventory.waste, inventory.low_stock and inventory.expiring. Consumer processing is separate evidence. Human actor attribution applies to new human operations; legacy/system actor NULLs remain.
- Proposal page 15: ADR-006 Accepted. Page 16: ADR-007 Proposed. PDF page 11 contains NFR-01 to NFR-09; the separately supplied Markdown adds NFR-10 to NFR-13.

REMAINING ACCEPTANCE AND COURSE HANDOFF

The owner accepts best-effort Auth audit for now; persistent failures can still lose an audit. Team work remains for shared NFR login wording, Auth event adoption, consumer deduplication/DLQ, TLS/CA and external HTTPS rollout, agreed-load Order p95, payment lifecycle and Notification-outage behavior.

The course package still needs a recorded clip under five minutes and submission. Suggested clip: DNS/paths (0:00-0:40), roles/TLS (0:40-1:30), replay/conflict (1:30-2:30), stock/history/readiness (2:30-3:30), evidence and remaining boundaries (3:30-4:30).

SOURCE AND RECEIPT

Original proposal: 25 pages; SHA-256 begins b6fbd067559a63cc. This addendum preserves the original. Detailed source reconciliation, ADRs and the credential-free verification JSON are in docs/architecture/owned-nfr-update-2026-10-25.md on the delivery branch.

Implementation diff SHA-256: 0771e44246b4f503a46a4920f7b1c8c07bec6c0ea0520d6500174fb049bee499